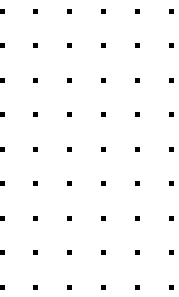


A Start-to-finish Guide on SOC 2 Compliance

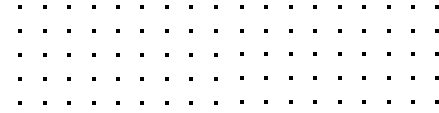
**Learn how to achieve SOC 2
compliance from a 10-year former
auditor and security expert.**



DRATA

Drata.com

A series of concentric, light blue curved lines that sweep across the bottom right corner of the page.



A Start-to-finish Guide on SOC 2 Compliance

Introducing the only guide you'll need to get you started on your SOC 2 compliance journey. This guide was put together by a 10-year auditor and cybersecurity risk management expert after helping thousands of customers achieve SOC 2 compliance.

Since there's a lot on here, let's get right to it.

Here's what we'll cover:

1. What is SOC 2?

- Difference From SOC 1 & SOC 3
- Why It Matters
- Why Startups Should Prioritize SOC 2

2. What is a SOC 2 Report?

- SOC 2 Type 1
- SOC 2 Type 2
- What's Included?
- Who Would Request It?

3. SOC 2 Audit Costs

- SOC 2 Type 1
- SOC 2 Type 2
- Additional Audit Costs to Consider

4. The Basics: Preparing for a SOC 2 Audit

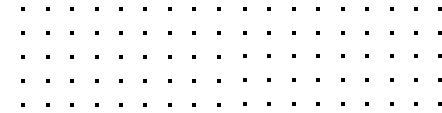
- SOC 2 Audit Checklist

5. How to Speed Up Your Compliance Journey

6. Automating SOC 2 Compliance

- What is SOC 2 Compliance Automation Software?
- Features to Look for in Compliance Automation Tools
- Key Benefits of Automating SOC 2

7. Bonus: Common SOC 2 Compliance Myths



Meet the Experts



Troy Fine

[Troy Fine](#) is a 10-year former auditor, now Senior Manager of Cybersecurity Risk Management and Compliance at Drata. He advises customers on building sound cybersecurity risk management programs that meet security compliance requirements.

Troy is a CPA, CISA, CISSP, and CMMC Provisional Assessor. His areas of expertise include, GRC, SOC 2 audits, SOC 2+ examinations, CMMC, NIST 800-171, NIST 800-53, Sarbanes-Oxley Section 404 compliance, HITRUST, HIPAA, ISO 27001, and third-party risk management assessments.



Richard Stevenson

[Richard Stevenson](#) is Manager of Cybersecurity Risk Management and Compliance at Drata. He advises customers on building sound cybersecurity risk management programs and security policies that meet security compliance requirements.

Richard is an AWS Certified Cloud Practitioner, CompTIA CySA+, and Shared Assessment Certified Third-Party Risk Assessor specializing in SOC 2, ISO 27001, NIST 800-53, NIST 800-171, SOX, HIPAA, third-party risk management, and enterprise risk management.

What is SOC 2?

SOC 2 stands for Service Organization Control 2 and is a security framework that defines how companies should manage, process, and store customer data based on the Trust Services Categories (TSC).

We will delve deeper into each one later in the guide but the five categories are:

- Security
- Availability
- Processing integrity
- Confidentiality
- Privacy

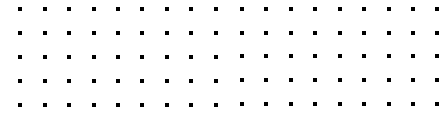
SOC 2 compliance is unique to each company because it's a set of Trust Services Categories as opposed to a prescriptive list of controls to mark off.

Every company's security practices will look different, meaning you can achieve SOC 2 compliance with custom policies and processes that are relevant to your business's operations.

What About SOC 1 or SOC 3?

As you might have guessed, SOC 2 isn't the only SOC around. The American Institute of Certified Public Accounts, or AICPA, developed two other types of SOC reports.

SOC 1 is focused on meeting financial standards, and **SOC 3** is a high-level, public-facing report with no confidential information. If you're asked for a SOC report concerning security and data, it's safe to assume what they're looking for is SOC 2.



Why It Matters

With risks rising and awareness about data security at an all-time high, it's no longer enough to say you have good security practices in place.

A growing number of companies across a variety of industries are requiring vendors to prove good security practices with a SOC 2 report.

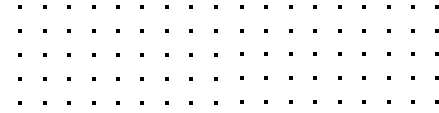
This means getting your policies and controls in order, and tracking your compliance over time. This applies to any service provider that stores, processes, or transmits customer or client data in the cloud—which is just about all of us, these days.

If you haven't had a prospective customer ask for a SOC 2 report yet, you might think you don't need one. For startups especially, it can be tempting to delay starting the compliance process in lieu of other priorities. But it's really only a matter of time—we're hearing from new customers everyday that they've started the process because their sales cycle stalled without one.

It's not exactly a quick process to become SOC 2 compliant either. It can take companies months to become SOC 2 compliant, meaning money left on the table for your company. Not to mention, most SOC 2 report requests are for SOC 2 Type 2, meaning you're being asked to prove you have stayed compliant over a long period of time (more on this in a minute).

The longer you take to become compliant, the further you can fall behind the competition.

Since compliance itself is a taxing process—and you'll need to prove that compliance over time—experts recommend making it a priority now before you're asked to provide a report.



Note for Startups: Why You Should Prioritize SOC 2

SaaS startups often focus on revenue generation, marketing, product design, functionality, and customer satisfaction. And all too often, they leave cybersecurity as an after-thought—at least until a large enterprise customer starts asking for an independent third-party attestation report.

When this occurs, companies begin a mad rush to answer customer questions, extensive security questionnaires, and implement customer-required cybersecurity controls in order to not lose the deal.

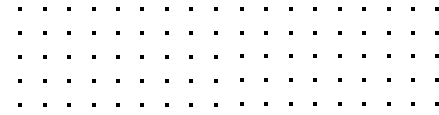
As you can imagine, this quickly turns into a mess, as everyone in the company is suddenly thrust into cybersecurity roles—decreasing the company's focus on revenue-generating initiatives. So to avoid this situation, here's why you should get started on SOC 2 now:

Prove to Enterprise Customers That Cybersecurity is a Top Focus

Cybersecurity is currently one of the most important issues at the C-Suite level at enterprise organizations. Because of this, they hold their vendors to strict cybersecurity requirements and expect them to undergo a SOC 2 attestation audit on an annual basis.

As part of the vendor vetting process, enterprise organizations require their vendors to provide them with a SOC 2 report.

Undergoing a SOC 2 audit in the early stages of your company will demonstrate to enterprise customers that cybersecurity was a primary focus from the beginning and continues to be a priority moving forward.



Avoid Significant Cybersecurity Gaps

To obtain a clean report, SOC 2 requires companies to have strong cybersecurity controls in place. These can include implementing multi-factor authentication (MFA) for all users that have accounts on applications that store, transmit, or process sensitive customer data, and encrypting data in transit and at rest. These are common requirements from enterprise customers.

Without an independent attestation, many SaaS startups will sacrifice security for ease-of-use.

When a SaaS startup is forced to show an independent auditor that they are meeting SOC 2 requirements, they will be forced to implement these types of controls from the beginning and avoid significant process re-architecture later on.

Gain a Competitive Advantage

Enterprise customers will expect SaaS vendors to have a SOC 2 audit performed annually and will not sign with vendors until the audit is completed.

By having a SOC 2 report in your hands prior to engaging prospects, you will make it easier for potential customers to vet you compared to your competition.

With a SOC 2 report, enterprises will spend less time performing due diligence as part of the sales cycle. If enterprises have to spend less time performing due diligence compared to your competition, then you will have a better chance of landing the large enterprise customers.

For more reasons why you should prioritize SOC 2 compliance, [check out this Forbes article](#).

What is a SOC 2 Report?

A **SOC 2 report is an attestation** by a certified public accountant (CPA) **stating that your organization meets the industry security standards** outlined in the official SOC 2 guidelines by the AICPA.

The report, typically requested by a prospective customer or client, is there to help them confirm that your company's security complies with or exceeds industry standards. In other words, you're safe to work with them and their data, customers, and systems are protected.

There are two types of SOC 2 reports:

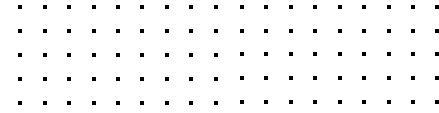
SOC 2 Type 1

SOC 2 Type 1 is a point-in-time report. This means the auditor checks your security at a single point in time.

Are you secure today? A Type 1 report would ask an auditor to check your security for that particular moment.

This report is a great way to check and make sure all the security measures you just put in place a few weeks ago meet industry standards. It can help you prove to leadership that all the hard work your team has been putting into compliance is going to pay off. And it can prove to prospective customers and clients that you are on your way to long-term, ongoing security compliance.

That said, Type 1 is considered a lower-value type of report because it doesn't show long-term commitment to compliance. It only shows that at one specific point in time, you were able to meet the standards.



SOC 2 Type 2

The most valuable SOC 2 report is Type 2. This report shows compliance over time—often covering a period of at least three months or up to a year.

In this report, the auditor looks at your compliance not just for last week, but for the last year (or last three or six months). This report helps prospective clients feel comfortable with your ongoing security standards.

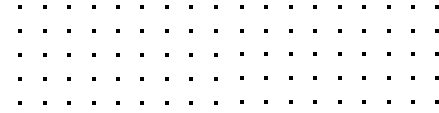
What's Included?

SOC 2 reports focus on one or more of AICPA's five Trust Services Categories: security, availability, processing integrity, confidentiality, and privacy.

Security is the only required criteria, but many companies choose to audit their availability and confidentiality because both requirements are straightforward and helpful to prove to customers their data is protected. For companies in healthcare, a privacy audit may also be requested. Even more rarely, companies will choose to include processing integrity criteria.

No matter which combination of Trust Services Categories you audit for, a completed SOC 2 report includes five core pieces of documentation:

- 1. Auditor report**
- 2. Management assertion**
- 3. Detailed service description**
- 4. Details specific to each of the Trust Services Categories being evaluated**
- 5. Test results**



Who Would Request It?

The company requesting a SOC 2 report is typically one that wants to hire you as a vendor.

They're asking for SOC 2 because they want to confirm your security compliance and feel safe working with you.

Sometimes they're requesting the report for their own peace of mind. Sometimes they need it to give their clients peace of mind. Sometimes they have industry standards to meet on their end. Or there are regulatory standards they have to comply with. Often, all four of these reasons intersect.

SOC 2 Audit Cost

For many businesses, understanding the investment—both time and money—that goes into SOC 2 is complex. Here's a breakdown of average SOC 2 audit costs to help you get a better insight into what you can expect.

But before we get to that, be sure to factor in the size and complexity of your organization.

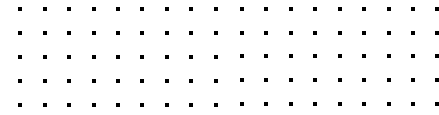
The size of your organization is usually an indicator of the complexity of your systems being audited and will have a major impact on the costs you can expect.

SOC 2 Type 1

Typical estimates for a small to midsize company range from **\$7,500 to \$15,000** for the audit alone. However, for larger businesses, this cost could be anywhere between **\$20,000 and \$60,000**.

SOC 2 Type 2

The audit alone for a small to midsize company for SOC 2 Type 2 reports costs an average of **\$12,000 to \$20,000**. For large organizations, total costs can range from **\$30,000 to \$100,000**.



Additional Audit Costs to Consider

Now, let's look a little bit closer at what can impact the total cost of the endeavor. The eight elements below differ significantly based on the needs of each unique organization.

Type 1 vs. Type 2

In general, a Type 2 audit will be more costly than a Type 1.

That's because a Type 1 report is just a broad picture of an organization's overall security at a specific point in time. Type 2 audits, however, are significantly more extensive and in-depth, and they also look at how the organization's established controls perform over time.

Keep this in mind when considering which type of SOC 2 audit you're going to do.

Scope

The time and effort required to conduct a SOC 2 audit vary depending on which Trust Services Categories are included in the scope.

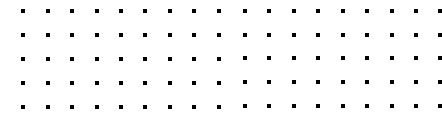
You'll need to consider the complexity of your system, your web applications, and the five Trust Services Categories.

In addition, audit costs could increase if you have multiple custom-developed applications in-scope for your audit and whether or not the applications share the same infrastructure.

Your Team's Time

When going through a SOC 2 audit, keep your team's workload and resources in mind.

Many companies don't consider the loss of productivity on other projects early on.



The main reason is that it isn't a readily apparent expenditure to account for. It's hard to know exactly how much these costs will add up to, but being aware of this is key to not falling behind in other parts of the business.

Hiring a Consultant

Looking for outside guidance is also an option.

Experts can help you better understand, prepare, and sort through the difficult tasks that come along with preparing for these audits.

However, be sure to do your research before choosing a consultant.

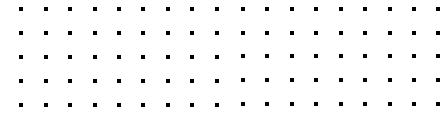
Security Tools and Employee Training

There are a few tools and services you may need to become SOC 2 compliant which will also add to your estimated cost.

This can include anti-virus software, password managers, vulnerability scanners, security incident and event management (SIEM) tools, and other native services offered by your cloud service providers.

Additionally, annual online security awareness training—whether provided by a third party such as a cybersecurity firm or in-house—is key to establishing a security-first culture, but there are several costs involved.

First, you have the cost of the training program itself and allocation time for your team to complete the training. You'll also need to factor in any costs that may come with changes to current workflows as you work towards staying as secure as possible and in compliance.



Penetration Testing

Another cost you'll need to consider is penetration testing.

As you prepare for your SOC 2 audit, penetration testing can help identify potential vulnerabilities in your defenses.

Through a set of activities performed by security experts, you'll be able to assess vulnerabilities in your applications, network infrastructure, and physical security barriers. Whether these experts are internal or hired from a third-party company, there will be costs associated with your organization's penetration test.

Tech Stack

At times, some tools require that you purchase a higher-tiered package to access additional security-focused features like multi-factor authentication.

So if you're going for SOC 2, keep in mind that the recurring cost of your tech stack may increase as well.

Compliance Automation Software

Selecting the right compliance automation platform can make the entire SOC 2 audit process easier.

Look for a tool that can grow with you and help monitor system and security settings, build an audit trail, and automate evidence collection.

While this may become a recurring cost, streamlining the execution of the audit with software and systems can lead to significant cost and time savings.

The Basics: Preparing for a SOC 2 Audit

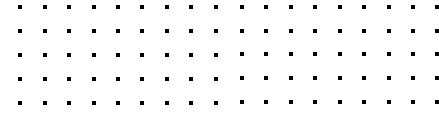
All of this may seem overwhelming, but it doesn't have to be. We've created this easy-to-follow checklist to jumpstart your compliance journey on the right track.

SOC 2 Audit Checklist

What goes into the preparation and execution of a SOC 2 audit?

These are the steps you can expect to take:

- ✓ Determine if a Type 1 is necessary
- ✓ Determine your scope
- ✓ Communicate the process internally
- ✓ Perform a gap assessment
- ✓ Remediate control gaps
- ✓ Update your customers and prospects
- ✓ Monitor and maintain controls
- ✓ Find an auditor
- ✓ Provide requested evidence to your auditor



1. Determine if a Type 1 is Necessary

To get started with SOC 2, the first step is to determine if you would like an auditor to perform a SOC 2 Type 1 audit prior to the auditor performing a more rigorous SOC 2 Type 2 audit.

When performing a SOC 2 Type 1 audit, auditors review policies, procedures, and control evidence to determine if controls are suitably designed to meet the applicable SOC 2 criteria. The audit covers a point in time and the resulting report will state whether or not controls were suitably designed as of a specific date.

When performing a SOC 2 Type 2 audit, auditors perform a more rigorous audit. In addition to determining if controls were suitably designed, they will also review evidence to determine that controls were operating effectively over a period of time to meet the applicable SOC 2 criteria.

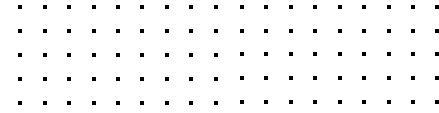
Because of the nature of a Type 1 versus a Type 2, organizations typically will engage an auditor to perform a Type 1 audit prior to a Type 2 audit. However, Type 1 audits do not need to be performed prior to completing a Type 2—organizations can choose to undergo a Type 2 audit without ever undergoing a Type 1 audit.

Customers will typically accept a Type 1 report for their vendors undergoing a SOC 2 audit for the first time, but they will more than likely expect a Type 2 report moving forward.

2. Determine Your Scope

SOC 2 audits cover a system which includes the following components as defined by the AICPA's attestation standards:

- Infrastructure
- Data
- Procedures
- Software
- People



As part of scoping, you will need to determine the system components that are in scope.

Beyond that, you'll also need to determine which Trust Services Categories to include. The Trust Services Categories are:

3. Security

According to the AICPA standards, security means:

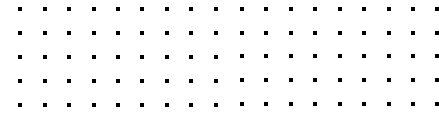


Information and systems are protected against unauthorized access, unauthorized disclosure of information, and damage to systems that could compromise the availability, integrity, confidentiality, and privacy of information or systems and affect the entity's ability to achieve its objectives.

This means following best practices like:

- Two-factor authentication
- Access controls
- Identity management
- Encryption
- Breach alerts
- Maintaining firewalls

It also means having well-documented security policies and procedures, a good security training program, and enforcing best practices with your infrastructure provider and vendors, among other things.



Availability



Information and systems are available for operation and used to meet the entity's objectives.

There is no set performance level required in the SOC 2 standard. When auditors evaluate availability, they're looking to see if you keep your promises in the SLA.

For example, if you guarantee 99.95% availability, are you hitting that metric? They also review the systems you have in place to ensure performance, support disaster recovery, and incident management.

Processing Integrity

As the AICPA standards explain, processing integrity is when,



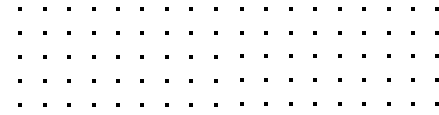
System processing is complete, valid, accurate, timely, and authorized to meet the entity's objectives.

In simple terms, this means the systems process as expected or promised. Auditors look for good monitoring and quality assurance practices, as well as error reports and how quickly system issues are addressed.

Confidentiality



Information designated as confidential is protected to meet the entity's objectives.



Meeting confidentiality standards typically means having encryption, access controls, and firewalls in place to protect customer data. It may also mean robust user permissions that ensure data is only accessible to those in the organization who truly need it.

Privacy



Personal information is collected, used, retained, disclosed, and disposed of to meet the entity's objectives.

In other words, personally identifiable information (PII) is private and users have full control over its use. This piece of the compliance puzzle is particularly important in light of ever-growing privacy regulations like GDPR and CCPA.

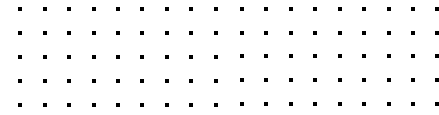
In this category, auditors are specifically looking for how well you communicate with customers about their data.

Customers should always know:

- How their data is used.
- How they can access and update their data.
- Their options are for opting out.
- Options for limiting data use.
- How they can delete their data, and more.
- If there is a data breach or incident along the way.

Standards also ask auditors to look at best practices around data access, retention, and deletion. Auditors review that you monitor your privacy compliance on an ongoing basis as well as keep track of privacy-related complaints, disputes, and incidents.

Remember, you don't have to include all five Trust Services Categories, Security is the only mandatory category. However, availability and confidentiality are frequently included.



Communicate the Process Internally

An imperative action to execute throughout your SOC 2 audit planning process should be to communicate internally with key players.

Your organization's executive management and department leaders (Human Resources, Engineering, DevOps, Security, IT, etc.) will be responsible for participating in implementing controls and providing evidence to the auditor.

Explaining the who, what, when, where, why, and how of the audit will be crucial to preparing employees for their obligations.

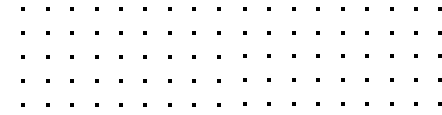
4. Perform a Gap Assessment

One of the first steps on your SOC 2 journey will be to perform a gap assessment. Look at your existing procedures, policies, and controls to help better understand your current security posture and which controls you still need to implement to meet the applicable criteria of the Trust Services Categories.

5. Remediate Control Gaps

Once your gap assessment has been completed, it can take time to remediate and ensure that SOC 2 control mandates are being achieved.

You will need to spend time with your teams reviewing policies, formalizing procedures, making necessary alterations to software, and any additional steps like integrating new tools and workflows. This will allow you to take the steps necessary to close gaps before the audit takes place.



6. Update Your Customers and Prospects

In the spirit of transparency and building trust, discuss with your team a few ways to promote your security practices with customers and prospects.

Although you don't have to announce that you're pursuing SOC 2, you can still outline the processes you have in place to keep their data safe.

On your website or social media, consider outlining a high-level overview of:

- Any continuous security control monitoring you have in place.
- Employee training.
- Penetration testing you've conducted.
- Data encryption procedures.

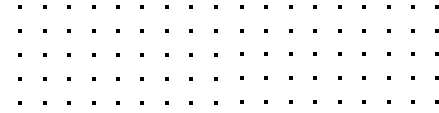
7. Monitor and Maintain Controls

Now that you've made remediations and added controls to reach SOC 2 compliance, establish processes that help you and your team continuously monitor and maintain those controls. If you haven't already, implement a tool that can automate control monitoring and evidence collection.

8. Find the Right Auditor for Your Organization

Before you begin looking for an audit firm, it's important to determine what you're looking for in an auditor.

The right auditor can do much more than conduct your audit—they can help you understand and improve your compliance programs, streamline the process, and ultimately achieve a clean SOC 2 report.



9. Provide Requested Evidence to Your Auditor

At this stage, you're ready to begin the audit process. Once you provide all the necessary information to your auditor, they will review evidence for each in-scope control, verify information, schedule any walkthroughs, and provide you with the final report.

Now, let's move on to ways you can speed up your compliance journey.

7 Proven Steps to Streamline Your Journey

For all of the companies that we've seen get SOC 2 audit-ready quickly, they all had something in common—they were all aware of these seven to-do's when they got started.

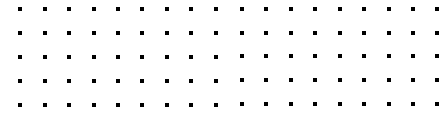
1. Use a Password Manager and Enforce MFA Everywhere

A password manager like 1Password or LastPass is an application designed to create, store, share, and manage your passwords and other authentication information for the systems you access.

It's important that your employees and contractors use a password manager to store their passwords for critical systems like GitHub, AWS, etc.

Employees should never share passwords over Slack, email, or text. Password managers make this much more feasible in everyday practice.

Multi-factor authentication is also made much easier with tools like 1Password, and should be enforced everywhere it's available—especially on AWS, GitHub, etc.



2. Enforce Best Practices on GitHub, Bitbucket, and GitLab

There are best practices when it comes to the security of your code and application. Doing these early will set you up for success in a number of ways, including SOC 2 audit preparation.

First, enable protected branches for your main and deployment branches. Set up a pull request template and place it in the root of your project or in a .github folder. Require reviews for pull requests that merge into production and restrict who can push to main and deployment branches.

Lastly, set up a CI system to run your tests that are required to pass for pull requests to be merged into production.

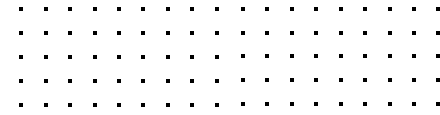
3. Track Your Vendors and Conduct Vendor Reviews

Start tracking all of the third-party applications like SaaS subscriptions and browser extensions that your company is using.

Understand what data you are sharing with them, and based on the criticality of the vendor, begin asking for their security documentation—including their latest SOC 2 report.

For your key subprocessors (like AWS), conduct a formal review of their SOC report. As your company grows, you'll be amazed at how many SaaS applications you're using every day.

Unfortunately, using a spreadsheet to track this is going to be painful, and likely never quite up to date as new tools get adopted frequently.



4. Conduct External Application Penetration Testing

A solid security practice is an annual penetration test conducted by an independent third party.

A penetration test (aka “pen test”) is an ethical hack of your system. It’s an authorized cyberattack meant to evaluate the security of your system and determine specific measures to take to fight against a real attack in the future.

There are a number of options available out there, from automated scripts to robust, manual tactics meant to penetrate and take advantage of your system. [Cobalt](#) has been an industry leader in the penetration testing space and is highly recommended and used by Drata customers.

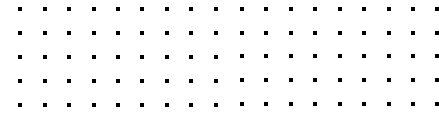
5. Conduct Background Screening, Security Training, and Track Policy Acceptance

When it comes to ensuring the security of your customers’ data, your company’s personnel are its first line of defense against threats.

That’s why your employees and contractors play such a key role in your SOC 2 journey.

If you’re not already, you’re going to need to start conducting formal background screens of your employees and contractors. You’ll also need to conduct annual security awareness training to ensure everyone is up to date with the latest security threats and ways to avoid security incidents. This is quite helpful not just for the company, but for your personnel to protect their own personal information.

All personnel will also need to read and acknowledge your company’s security policies, ranging from your code of conduct to your acceptable use policy.



Tracking all of this can be a project management nightmare, especially with information spread across shared folders, some in your HR system, and some in your LMS (learning management system) so consider a compliance automation tool to help track and monitor this in one place.

6. Use a MDM Solution

Mobile device management tools like Jamf and Hexnode allow you to provision and wipe company-owned machines on behalf of your employees. This helps ensure workstations are configured correctly and securely, enforcing things like hard disk encryption, automatic operating system updates, auto-locking with screensaver, etc.

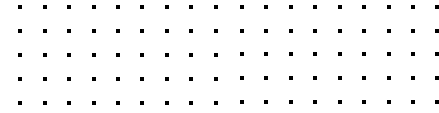
If you're a Drata customer and aren't ready for the expense of an MDM solution and still have a BYOD policy, we provide a lightweight toolbar agent that can be installed across MacOS, Windows, and Linux machines.

The Drata Agent uses read-only access via OSQuery to monitor specific requirements for compliance purposes and provides real-time view across all devices. You'll be able to see exactly what machines are configured properly, and be assured your personnel are provided with the instructions to configure theirs accordingly.

7. Enforce Best Practices Across Your Infrastructure Provider

There are a handful of practical measures and best practices to follow when it comes to configuring your infrastructure:

- Enable CloudTrail (AWS) logs and/or Google Cloud Logs (GCP).
- Use IAM accounts only with 2FA enabled.
- For Security Groups (AWS) and Firewall Rules (GCP), limit open ports.
- For cloud storage (S3 on AWS), disallow public access to S3, enable logging, versioning, and encryption.
- For RDS or CloudSQL, limit access to inside the VPC, enable encryption, and enable automatic daily snapshots.



Voila, you're going to have a much easier audit preparation process. But without a compliance automation tool, this will require you to take a lot of screenshots to prove to an auditor that you're doing those things correctly and consistently.

Even if you're not already doing all seven of these things, you're already ahead of the game by being aware of them. There's of course a lot more involved in getting audit-ready.

Since we've touched on some of the benefits of implementing a compliance automation tool to get and stay-audit ready, next we'll cover how to choose the right one for your organization.

SOC 2 Compliance Automation Software

There is no magic solution that will make your company instantly compliant. However, good SOC 2 automation software can help you understand what you need to do to become compliant, automate the monitoring and evidence collection of that compliance posture over time, and instantly alert you when gaps form or your posture is at risk.

Keep reading for a breakdown of SOC 2 compliance software, its benefits, top features to look for, and what your journey to compliance can look like with automation.

What is SOC 2 Compliance Automation Software?

SOC 2 automation software helps you stay SOC 2 compliant via 24-7 security control monitoring across your SaaS services.

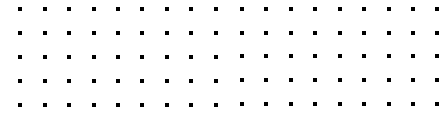
A good automation tool should give you control across your security program and instant visibility into your compliance and security posture.

It should also eliminate the complicated headaches of manual monitoring, evidence collection, and compliance audits—saving your team significant time and money.

9 Features to Look for in a SOC 2 Automation Tool

What should you look for in your automation tool?

The answer boils down to ease of use, depth and breadth of integrations, and features that take the burden of compliance off your team as much as possible.



The best tools are built by companies who practice what they preach. Look for companies with in-depth security and compliance experience, and their own solid SOC 2 compliance program.

After all, if your vendor's security is messy, how can they keep yours sharp and aligned with industry standards?

As for features, we recommend looking for a solution that has:

1. Continuous Control Monitoring

Spot checks are no longer enough. **You need a system that will monitor your compliance continuously and alert you quickly if your security is at risk.**

For example, systems should alert you if contractor access isn't terminated at the end of a contract, if a new employee skips part of the security onboarding process, or a new customer database that was created isn't encrypted at rest—now extrapolate across hundreds of controls.

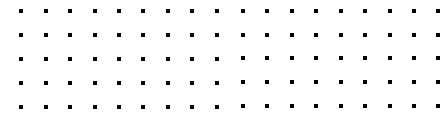
2. Automated Evidence Collection

Doing away with complicated spreadsheets, folders full of screenshots, and other manual compliance tracking hassles is the point of automation software. **If the tool you're looking at doesn't automatically collect evidence** and generate real-time, sharable reports upon request, **run in the other direction.**

3. Scalability

The automation platform you choose should be able to scale as your organization and compliance program grows. **Look for a platform that can help you achieve compliance for multiple frameworks, regulations, products, and business lines** while giving you full visibility into the progress you've made towards fulfilling their specific requirements.

So whether you're expanding to different global markets or offering product solutions across different industries, the platform you use should be able to meet your unique compliance needs.



4. Employee Onboarding and Offboarding

Trackable, consistent employee onboarding and offboarding is a key part of SOC 2 compliance.

Look for a system that lets you automate onboarding and offboarding, track security training, get employees to read and sign off on procedures, and flag issues before they arise. For example, flagging if security training is due by tomorrow and hasn't been completed.

5. Vendor Management

Getting your own internal security ducks in a row is important, but your compliance also relies on your vendors. This is why **any good automation software should include vendor management**.

6. Auditor-approved Security Policies

Keeping up with the latest security policies is a hefty task. **The best automation software gives you a head start by providing auditor-approved security policy templates** you can use as a foundation to develop your compliance program.

7. Simple and Straightforward Tools

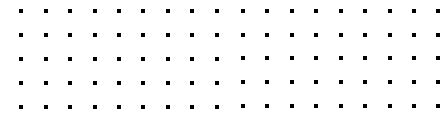
Your new software should be easy to use and configurable. **This means custom controls, a straightforward dashboard, and intuitive interfaces**. It should also mean great customer support whenever you have questions about the tool or want to suggest a new feature.

8. Compliance Experts On Call

Most tools will offer you some tech support, but the best of the **best will also offer you support from compliance experts**. In-app messaging and support can make the difference between a good system and one truly set up with customer success top of mind.

9. Trust and Transparency

Last but not least, look for a compliance automation partner that prioritizes trust and transparency at every level of your security and compliance program. **Your platform should provide continuous monitoring and in-depth integrations (not just plugins)** for the most accurate data—while ensuring processing integrity—to further promote trust to your auditor and customers.



Key Benefits of Automating SOC 2

From time savings to improved and streamlined relationships with your auditors, here are just a few of the benefits you can expect from implementing SOC 2 compliance automation software.

Saves Time

If you're running your compliance program manually, you're likely devoting a significant amount of time to tedious tasks like manipulating spreadsheets and pivot tables, organizing screenshots and other evidence in shared folders, and manually tracking incidents, assets, and vendors.

One of the main benefits of SOC 2 automation software is that all those time-consuming compliance tasks pretty much disappear.

The system handles evidence collection, onboarding and training for personnel, tracking of vendors and assets, risk assessment, and control mapping. It offers simple dashboards where you can check your status in an instant.

Saves Money

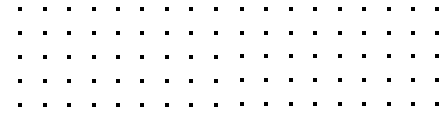
Time is money, as they say, so if your teams are spending hours, weeks, or even months getting your compliance program off the ground or back on track, you're losing money and productivity. Not to mention any budget that goes to partners, consultants, or new tools.

With SOC 2 automation software, you can eliminate many of those costs.

Lets You Provide Reports On Demand

When a prospective customer asks for assurance, the manual process of answering security questionnaires can take a long time.

With an automated system, real-time reports can be generated to answer security questionnaires and auditors can download available control evidence with only a few clicks.



This is simpler for your team, for your prospective customers, and for the auditors.

An advanced platform will enable you to publicly display the daily security and compliance measures your business is taking. Share continuous, real-time control monitoring, certifications, attestations, policies, and more on your page.

Maintains Security

SOC 2 isn't just about proving security, it's about being secure. Having the right controls in place for customer data, confidential information, and system availability will keep your business running smoothly, give leadership peace of mind, and save you from potential legal issues and customer churn.

Automation software makes sure your security program is running smoothly once it's established and in place—not only for audits, but to maintain a strong security posture.

Provides Key Insights

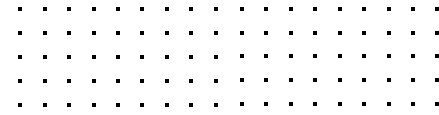
How can you improve security? Do your privacy protections need updating? Are employees playing fast and loose with your standards?

Automation software can help you get insights into how your security program is operating at any given point and where you can improve.

Reduces Risk of Human Error

15% of unplanned downtime is caused by human error. Automation can mitigate this risk by taking repetitive tasks off our to-do lists and completing them the same way every time, and by alerting us to changes in human behavior.

If, for example, an employee fails to complete the required security training, the system will notify you. If someone tries to access something they shouldn't, it'll trigger an alert. This mitigates not only the risk of a malicious attack on your systems or data, but also the risk of honest mistakes (like forgetting to finish a task) that could derail your compliance.



Makes Life Easier for Your Auditor

Good automation software means faster audits and happier auditors.

Instead of relying on spot checks and assuming compliance has been continuous, they can confirm continuous compliance via monitoring and reports. Instead of collecting evidence from multiple sources and confirming through multiple avenues, they can pull evidence directly from your SOC 2 automation tool.

This means less back and forth between auditor and company, and a faster and cheaper process for both the auditor and the company. Win-win.

No security program is set-it-and-forget-it, no matter how good your automation software. Put someone in charge. Make sure they check in regularly, keep an eye on new developments (such as new privacy laws in the markets you serve), and update your automation software as needed.

Automation software should make compliance much less complicated and should take a lot of the busywork off your teams' plates, but you'll still need someone keeping an eye on your program and using the new alerts, reports, and monitoring to stay far ahead of any risks.

Bonus: 7 Myths About SOC 2 Compliance to Keep In Mind

There's a lot of misinformation out there surrounding SOC 2 compliance so we wanted to dispel the most common myths we hear.

1. Companies Pass or Fail SOC 2 Certifications

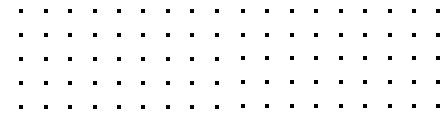
A SOC 2 audit does not result in a certification.

After an audit firm performs an audit, they will produce an attestation report and render their opinion on the design and operating effectiveness of controls. This is why you will hear companies offer their SOC 2 report after an audit, because SOC 2 is not a type of compliance certification unlike HIPAA.

SOC 2 audits offer more comprehensive results than simply passing or failing. Below are four possible results of an audit.

- **Unqualified:** Controls were designed appropriately and operating effectively to meet the applicable criteria.
- **Qualified:** Controls were designed appropriately and operating effectively to meet most of the applicable criteria, but a couple criteria were not met.
- **Adverse:** Controls were not designed appropriately and were not operating effectively to meet the applicable criteria.
- **Disclaimer:** The auditor could not render an opinion due to limitations in performing audit procedures.

It's important to note that you can receive control exceptions during the audit and still receive an unqualified opinion.



2. SOC 2 Has Required Controls

SOC 2 does not have required or prescriptive controls. Instead, SOC 2 has a set of categories which we've covered above.

Organizations are responsible for implementing controls that simultaneously meet both their needs as a company and the data they manage, and that meet the applicable criteria associated with the categories they're choosing to address in their SOC 2 audit.

3. Companies Can Use Their Vendor's SOC 2 Report

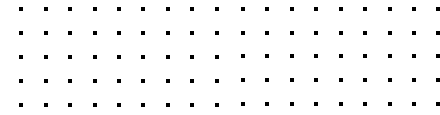
Organizations need to undergo their own SOC 2 audit to obtain a SOC 2 report of their own, even if their SaaS application is hosted in the cloud (AWS, AZURE, GCP, etc.).

The Shared Responsibility Model standard states that organizations and hosting providers are responsible for security in the cloud.

Because of the Shared Responsibility Model, customers will expect organizations to understand their responsibilities for securing their environment and undergo their own SOC 2 audit to confirm that the controls within their responsibility are operating effectively.

4. SOC 2 Only Covers Infrastructure and Software Controls

SOC 2 can cover a range of controls, depending on your specific organization and vertical. Potential controls in addition to infrastructure and software controls will include policies, onboarding/offboarding procedures, risk management, training, governance, and vendor management.



5. SOC 2 Proves Compliance to Other Frameworks

This is another popular myth.

SOC 2 does not prove compliance to other standards.

While at Drata we're excited to tell customers that if you're SOC 2 compliant, you may be on your way to meeting the criteria set forth by other standards, achieving SOC 2 compliance doesn't automatically mean you're compliant with a framework like PCI DSS.

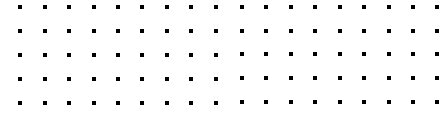
To meet multiple frameworks, companies can consider a SOC 2+ audit, which requires expanding controls to meet the additional framework like HIPAA.

6. SOC 2 Audits Can Be Completed in Weeks

While it's possible for smaller organizations to use a SOC 2 automation platform and obtain a SOC 2 Type 1 report from a CPA firm within two to three weeks of purchasing a platform, this is not typical for most companies.

In addition, organizations will also want to engage a CPA firm to perform a SOC 2 Type 2 audit, since the Type 2 audit covers a period of time and includes testing the operating effectiveness of controls.

An organization should not start their Type 2 audit period until their controls have been implemented. Therefore, even if it only took an organization two to three weeks to set up all of their controls, they would then need to wait a minimum of three to four months before an auditor could perform the Type 2 audit.



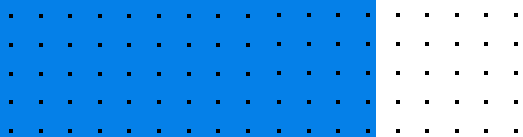
7. Auditors Don't Want to Interact During Your Audit

It's a common misconception that auditors don't want to interact during an audit and they want companies to fail—a misconception we've addressed.

Auditors should not be made out to be your enemy. They actually want the organizations they are auditing to succeed.

Auditors prefer to collaborate with their customers well ahead of the planned audit start date, so that audit procedures are conducted efficiently and customers are set up for success.

The last thing auditors and the organizations want are surprises during the audit. Collaborating early and often with your auditor is a better approach for success than engaging in any advertised "touchless" audit (beware of such terms).



Automate SOC 2 Compliance

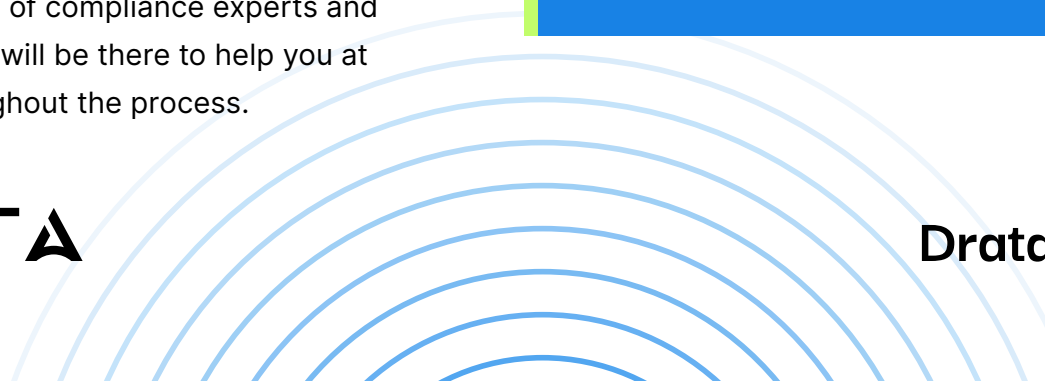
For most companies, achieving SOC 2 compliance can be challenging.

With so many people and moving parts involved, manually managing SOC 2 with multiple spreadsheets can quickly become inefficient. As you pursue SOC 2 compliance, you need a central location to continuously monitor controls, automate evidence collection, facilitate auditor collaboration and requests, and assess risk.

With Drata, you'll have this and more. With built-in security training and endpoint monitoring, a library of 20+ auditor-approved policies, and 75+ native integrations, you will cut hours from your SOC 2 compliance journey. On average, customers with 11 to 300 employees save 732 hours with Drata. Not to mention, a team of compliance experts and former auditors will be there to help you at any point throughout the process.

As your company grows, you can use our workflow automation to streamline and scale activities like control monitoring, evidence collection, asset and personnel tracking, and access control review for other frameworks and standards. By creating a single source of truth in the Drata Platform, your team saves time responding to requests and answering auditor questions, reducing overall compliance costs.

If you're ready to check out a compliance automation platform that can automate the tasks covered in this guide and more, **[schedule some time](#)** to talk with us.



DRATA

Drata.com